

Postal address:
Box 8114
104 20 Stockholm
Website:
www.imy.se
Email:
imy@imy.se
Phone:
08-657 61 00
1(9)

Vklass AB

Smedjegatan 2c, 1 tr
13154 NACKA

Decision following supervision according to the data protection regulation – Vklass AB

Decision of the Swedish Authority for Privacy Protection

The Swedish Authority for Privacy Protection (Integritetsskyddsmyndigheten) finds that Vklass AB, in its capacity as a data processor, has processed personal data in violation of Article 32.1 of the General Data Protection Regulation (GDPR). This occurred when personal data from Vklass AB's learning platform Vklass was exposed publicly on a website on the internet from late 2021 until September 2022. Vklass AB has not taken appropriate technical and organizational measures to ensure a security level that is appropriate in relation to the risk of processing and has thus not continuously ensured the confidentiality of the personal data and protected it against unauthorized disclosure and unauthorized access.

The Swedish Authority for Privacy Protection issues a reprimand to Vklass AB under Article 58.2 b of the GDPR for the identified violation.

The Swedish Authority for Privacy Protection orders Vklass AB under Article 58.2 d of the GDPR to take appropriate technical and organizational measures in accordance with Article 32 to ensure the company's (i) ability to identify anomalous events in the learning platform Vklass and (ii) ability to traceability in the learning platform in order to detect and determine the cause and extent of a personal data incident that has occurred.

Report on the supervisory matter

Starting point for the supervision

In September 2022, the Swedish Authority for Privacy Protection (IMY) received reports of personal data incidents from about sixty data controllers. The data controllers conduct both municipal and private school and educational activities and use the learning platform Vklass (the Platform) provided by Vklass AB (Vklass or the company) in their respective operations. The relevant data controllers are, or have at least been, customers of Vklass. The Platform is primarily used for communication between students, their guardians, and school staff. The reports concerned the unauthorized publication of personal data related to the Platform on a publicly accessible website on the internet. In the reports, the data controllers indicated that there had been unauthorized disclosure of or unauthorized access to personal data processed in the Platform.

In light of the reports, IMY initiated supervision of Vklass regarding the personal data processing that occurs on the Platform. The handling has been conducted through written correspondence.

What Vklass has stated

Vklass has primarily stated the following.

Vklass provides the Platform, which is a learning platform for school and educational activities. It is used by students, their guardians, and school staff. Vklass is a data processor for the customers (data controllers) who have submitted a report of the personal data incidents to IMY. In 2021, Vklass had 77 customers, and as of October 1, 2022, the Platform had 427,207 active accounts.

On September 21, 2022, Vklass received an email from a user of the service informing that there was a search service on the website www.zenbase.se (Zenbase) where one could search for personal data

about students. Several of the data appeared to originate from the Platform. On the same day this was discovered, Vklass's legal representatives sent a message to the operator behind Zenbase requesting that the unauthorized publication cease. The operator behind Zenbase was a student attending one of the schools that use the Platform. Furthermore, Vklass sent a message to all its customers to inform them of the discovered personal data incidents and simultaneously urged them to report to IMY. During the night of September 22, 2022, all content on Zenbase was removed.

After Vklass's investigations, the following could be established. The likely scenario is that a student who had access to the Platform, either alone or together with others, exploited a vulnerability that previously existed in one of the Platform's APIs. The student manipulated API calls against the service's address books and then saved personal data from the Platform to their own database. In this way, the student was able to acquire more information from the Platform than their access rights allowed. The student then built Zenbase where the obtained data was published openly on the internet. The relevant vulnerability has now been addressed as a result of several changes made to the Platform during 2021. Another scenario for how the personal data incidents may have occurred is that several users from different schools collaborated by retrieving data, to which each of them had authorized access, as there is a separation between the data controllers' personal data in the Platform. The data was then published on Zenbase.

Vklass reported the incident and the suspected student to the police on September 22, 2022. The student was simultaneously suspended from the Platform.

After Vklass's checks on Zenbase, it was established that the following categories of personal data about students and school staff were available on the website before the content was removed:

- First and last name
- Nickname
- Image

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-9092

3(9)

Date: 2023-08-24

- class
- email address
- phone number.

It was only possible to retrieve information about email addresses and phone numbers from the Platform if the user had chosen to display that information to other users attending the same school. Regarding nicknames and images, such information was only available provided that the user had chosen to enter or upload this on the Platform. The information that Vklass could find on Zenbase generally did not include data about phone numbers, email addresses, images, or nicknames. The Platform is not designed to handle protected personal data.

Information about nicknames was only exposed in two places on the Platform: on each user's profile page and in the Platform's address books. Regarding the profile pages, a log is maintained that records when a user opens such a page. After a review of the logs, it was determined that the data had not been retrieved from the profile pages. Therefore, the suspected student must have accessed them via the Platform's address books by exploiting a vulnerability that previously existed in one of the Platform's APIs.

It has not been possible to determine how many customers (data controllers) were affected by the relevant personal data incidents. Vklass knows that at least three customers have been affected, but likely more than that have been impacted. It has also not been possible to ascertain how many registered individuals were affected or what information about them was retrieved, as the API calls made against the Platform's address books are not logged.

There is no knowledge of the exact times when the unauthorized intrusions into the Platform occurred

and also how long they lasted. However, they are assessed to have occurred sometime during 2021, although it cannot be ruled out that they occurred earlier than that. The student suspected of being behind the intrusions had had an account on the Platform since 2016. The domain name zenbase.se was registered in July 2021.

Vklass has posed questions to, among others, the suspected student to obtain answers on how they went about retrieving personal data from the Platform and what information was published on Zenbase. However, the student has not responded with any answers.

Regarding the security of the Platform, several different types of protections and recommended methods have previously been implemented for the environment that Vklass uses. The Platform has, among other things, protection against denial-of-service attacks and SQL injections.

After the incidents were discovered, the following measures have been taken to further enhance security. A new feature called rate limiting has been implemented. Through this feature, a single user is prevented from making too many calls to the Platform within a certain time interval. If the user exceeds the number of allowed calls, they are blocked from making further calls for a certain period. This complicates, for example, the use of malicious programs (scripts) that make automated calls to the Platform in order to retrieve large amounts of information.

2 IMY's comment: A method for data intrusion that exploits a vulnerability in SQL. SQL is a programming language used to retrieve and modify data in a relational database.

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-9092

4(9)

Date: 2023-08-24

Additionally, a bot protection system has been installed that is specifically tailored for Vklass's unique traffic patterns.

Justification of the Decision

General Responsibility for Processing Personal Data

According to the principle of accountability in Article 5.2 of the General Data Protection Regulation (GDPR), the data controller is responsible for compliance with the principles described in the first paragraph of the article, including the security principle (Article 5.1 f of the GDPR). The principle of accountability is further developed in Article 24, which states that the data controller must implement appropriate technical and organizational measures to ensure and be able to demonstrate that processing is performed in accordance with the GDPR. These measures must be reviewed and updated as necessary. The principle of accountability is also reflected in Article 28, which establishes the obligations of the data controller when engaging a data processor. A data processor is one who processes personal data on behalf of a data controller. The data processor is responsible for complying with the provisions of the GDPR that are directed specifically at the processor, including Articles 32 and 33.2. Furthermore, a data processor may become liable for violations of the GDPR that result from the processor's failure to comply with the data controller's instructions.

Vklass, which provides and is responsible for the Platform, is a data processor in relation to the educational institutions (data controllers) that use it. The Platform handles, among other things, personal data about students, their guardians, and school staff.

Obligation of the Data Processor to Notify Data Controllers

According to Article 33.2 of the GDPR, a data processor must notify the data controller without undue delay after the processor becomes aware of a personal data incident. It is then the responsibility of the data controller to assess whether the personal data incident is such that it must be reported to the competent supervisory authority. For the data controller to fulfill its reporting obligation, it is necessary that the data processor promptly informs the controller.

Vklass has not been able to inform the data controllers whether they have been affected by the incident or not. The fact that Vklass has been unable to determine this is a deficiency that fundamentally relates to shortcomings in technical and organizational measures, which are detailed

below. IMY notes that Vklass has urged all data controllers to report a personal data incident to IMY and has notified them without undue delay. Therefore, IMY finds no reason to criticize Vklass under Article 33.2 of the GDPR.

Obligation to Implement Appropriate Technical and Organizational Measures

Both the data controller and the data processor must, according to Article 32.1 of the GDPR, implement appropriate technical and organizational measures to ensure a suitable level of security to protect the data being processed.

3 IMY's comment: Bot protection detects and blocks malicious bots that unlawfully seek to access data on a website or in an application. A bot is a computer program designed to automatically perform predefined activities.

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-9092

5(9)

Date: 2023-08-24

In the assessment of which technical and organizational measures are appropriate, the data controller and the data processor shall take into account the latest developments, the implementation costs, and the nature, scope, context, and purposes of the processing, as well as the risks to the rights and freedoms of natural persons. According to Article 32.1, appropriate protective measures include, among other things:

- a) pseudonymization and encryption of personal data,
- b) the ability to continuously ensure confidentiality, integrity, availability, and resilience of processing systems and services,
- c) the ability to restore availability and access to personal data in a timely manner in the event of a physical or technical incident, and
- d) a procedure for regularly testing, assessing, and evaluating the effectiveness of the technical and organizational measures intended to ensure the security of processing.

According to Article 32.2 of the General Data Protection Regulation, in assessing the appropriate level of security, special consideration shall be given to the risks posed by the processing, in particular the risk of accidental or unlawful destruction, loss, or alteration, or unauthorized disclosure of or access to personal data that has been transmitted, stored, or otherwise processed.

Vklass is the provider of the Platform. The company, as a data processor, has an obligation under the General Data Protection Regulation to implement appropriate protective measures to ensure an adequate level of security for the personal data that Vklass processes on behalf of the data controllers. What constitutes appropriate protective measures should not be understood as an arbitrary assessment but rather as an assessment that is adequate based on the nature, scope, context, and purposes of the processing, as well as the risks to the individual's rights and freedoms.

In this case, it concerns a learning platform intended to provide students, their guardians, and school staff with a communication channel. The students are largely children, and children's personal data has special protection under the General Data Protection Regulation (Recital 38). Many school and educational activities use the Platform, which is used daily by a large number of people. Vklass has stated that more than 70 different data controllers used the Platform in 2021 and that the Platform had over 400,000 active accounts as of October 1, 2022.

One of the reasons for communication occurring on a specific platform rather than on general open channels is that this communication needs to be able to take place in a trustworthy manner and not be accessible to everyone. This means that whether it concerns students, their guardians, or school staff, they all have the right to expect that their personal data is processed in a manner that ensures that this data is neither unlawfully disclosed nor accessed by unauthorized persons. The publication of personal data from the Platform on a website open for anyone to read on the internet has constituted an unauthorized disclosure of data according to the General Data Protection Regulation.

Vklass has indicated that the likely scenario for the relevant personal data incidents was that a student with certain access rights to the Platform exploited a vulnerability that previously existed in one of the Platform's APIs. In this way, the student could gain access to the data in the address books available on the Platform. Vklass has not itself discovered that data was extracted from the Platform, nor has the company been able to specify when the unauthorized intrusions occurred or how long they lasted. Vklass relies on the information that the company has found after its own searches on Zenbase and Swedish Authority for Privacy Protection

Diary Number: IMY-2022-9092

6(9)

Date: 2023-08-24

assesses that these have been extracted from the Platform during 2021, although the company cannot rule out that it may have also occurred prior to that time. The suspected student had an account with the Platform since 2016. Vklass is aware that the vulnerability suspected to have been exploited was addressed in 2021 as a result of various changes that Vklass implemented in the Platform.

Furthermore, Vklass has indicated that an alternative scenario to the incidents in question could be that several users from different schools collaborated by retrieving data, to which each of them had authorized access in the Platform, and then compiled the data and published it on Zenbase.

Vklass is aware that at least three data controllers have been subject to the relevant data incidents, but suspects that more than that may have been affected. However, Vklass has not been able to determine the full extent of the incidents. The company has stated that it cannot specify which data controllers were affected or which individuals had their personal data disclosed on Zenbase. The reason for this is that the API calls, which are suspected to have been manipulated and which are made against the address books in the Platform, are not logged.

As stated above, Vklass has not itself discovered that the data was extracted from the Platform. The company has not been able to account for the extent of the relevant data incidents and has also not been able to determine the underlying cause of them, i.e., whether it involved a user who improperly extracted information from the Platform through manipulated API calls or whether it was instead a matter of several users collaborating by obtaining information to which each of them had access in the Platform. The fact that Vklass has not been able to determine the extent of, or the underlying cause of, the data incidents indicates that there have been deficiencies in the company's logging and monitoring systems.

The ability to have control over what is happening, and what has happened, in an organization's various IT systems is fundamental to maintaining the security of the personal data processed there. This is particularly important in relation to organizations that provide and administer IT systems for other businesses in a manner similar to how Vklass does for its customers, i.e., the data controllers. It can be noted that Vklass lacks system monitoring concerning the API calls made against the Platform's address books.

Adequate monitoring of this part of the Platform would have given Vklass the opportunity to detect anomalous events and identify which data had been retrieved from the Platform, who or which users had retrieved the data, and whether a user had gained access to data that they were not authorized to access. The fact that Vklass has not been able to do this in relation to the data retrieved from the Platform's address books indicates security deficiencies and that Vklass has not had the ability to continuously ensure the confidentiality of the personal data processed in the Platform and to protect it against unauthorized disclosure or unauthorized access.

In summary, IMY finds that Vklass has not taken appropriate technical and organizational measures to ensure a level of security that was suitable in relation to the risks associated with the processing. The reason for this is that Vklass has not had an adequate logging and monitoring system in place regarding the API calls made by the Platform's users against the service's address books. Vklass has thus processed personal data in violation of Article 32.1 of the General Data Protection Regulation.

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-9092

7(9)

Date: 2023-08-24

Vklass has taken measures to improve the security of the Platform following the discovery of the relevant personal data incidents, including the implementation of a so-called rate limiting and a customized bot protection. IMY considers it positive that Vklass has strengthened security in this regard and thereby increased its protective capacity, but IMY also assesses that there are still shortcomings regarding the company's internal logging and monitoring systems. Maintaining the necessary logs is an important protective measure to map and determine the cause behind, and the extent of, a personal data incident that has occurred.

Choice of Intervention

Article 58.2 and Article 83.2 of the General Data Protection Regulation (GDPR) state that IMY has the authority to impose an administrative fine. Depending on the circumstances of the individual case, an administrative fine may be imposed in addition to or instead of the other measures referred to in Article 58.2, such as an order or a prohibition. Furthermore, Article 83.2 outlines the factors to be considered when deciding whether to impose an administrative fine and when determining the amount of the fine. If it concerns a minor infringement, IMY may, as stated in Recital 148, instead of imposing a fine, issue a reprimand in accordance with Article 58.2 b. Consideration should be given to aggravating and mitigating circumstances in the case, such as the nature, severity, and duration of the infringement, as well as previous relevant infringements.

IMY has determined that Vklass has processed personal data in violation of Article 32.1 of the GDPR. A violation of that provision may lead to an administrative fine.

In assessing the seriousness of the infringement, IMY can note that Vklass is a professional service provider that provides and administers the Platform for educational activities. Many organizations use the Platform, and there are many registered users on it as a whole. Many of these are children and therefore particularly deserving of protection. Vklass thus has a significant responsibility to provide a secure service.

Vklass has lacked system monitoring regarding the API calls made to the Platform's address books for the relevant personal data. Such monitoring would have allowed Vklass to detect anomalous events and identify which data had been retrieved from the Platform. The absence of such system monitoring and logging has resulted in Vklass not discovering the incidents itself and not being able to specify which data controllers or registered users have been affected or when this occurred.

At the same time, IMY can note that there is both access control and monitoring and logging in parts of the service. The personal data of the various data controllers are separated, and therefore a retrieval involving multiple data controllers should not be possible. The personal data retrieved from the address books did not involve sensitive personal data, personal identification numbers, or protected personal data. There were also no assessments or free text involved; rather, the data that was disclosed concerned contact information such as names and email addresses.

IMY can also confirm that Vklass acted promptly when it became aware of the incidents by contacting all data controllers who could have been affected. Vklass also contacted Zenbase directly and urged the operator behind the website to cease publication, which also occurred. Vklass has since taken measures to improve security by implementing rate limiting and a customized bot protection.

Overall, this means, according to IMY's assessment, that it would not be proportionate to impose a fine on Vklass for the identified infringement. The company shall therefore, based on Article 58.2 b of the GDPR, be given a reprimand instead. As noted above, IMY believes that Vklass still lacks an adequate system to appropriately monitor the personal data processing occurring in certain parts of the Platform, i.e., the Platform's address books. For this reason, IMY believes there are grounds to instruct Vklass under Article 58.2 d of the GDPR to take technical and organizational measures in accordance with Article 32 to ensure the company's ability to identify anomalous events and to ensure traceability in the Platform in order to detect and determine the cause and extent of a personal data incident that has occurred. If API calls are allowed to the Platform's address books, a suitable measure should include,

among other things, event logging that records user calls.

This decision has been made by the unit manager Katarina Tullstedt after presentation by IT and information security specialist Katarina Bengtsson and lawyer Per Nydén.

Katarina Tullstedt, 2023-08-24 (This is an electronic signature)

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-9092

8(9)

Date: 2023-08-24

How to Appeal

If you wish to appeal the decision, you should write to IMY. Indicate in your letter which decision you are appealing and the change you are requesting. The appeal must be received by IMY no later than three weeks from the day you received the decision. If the appeal is submitted in a timely manner, IMY will forward it to the Administrative Court in Stockholm for consideration. You may email the appeal to IMY if it does not contain any privacy-sensitive personal data or information that may be subject to confidentiality. The authority's contact details are provided on the first page of the decision.